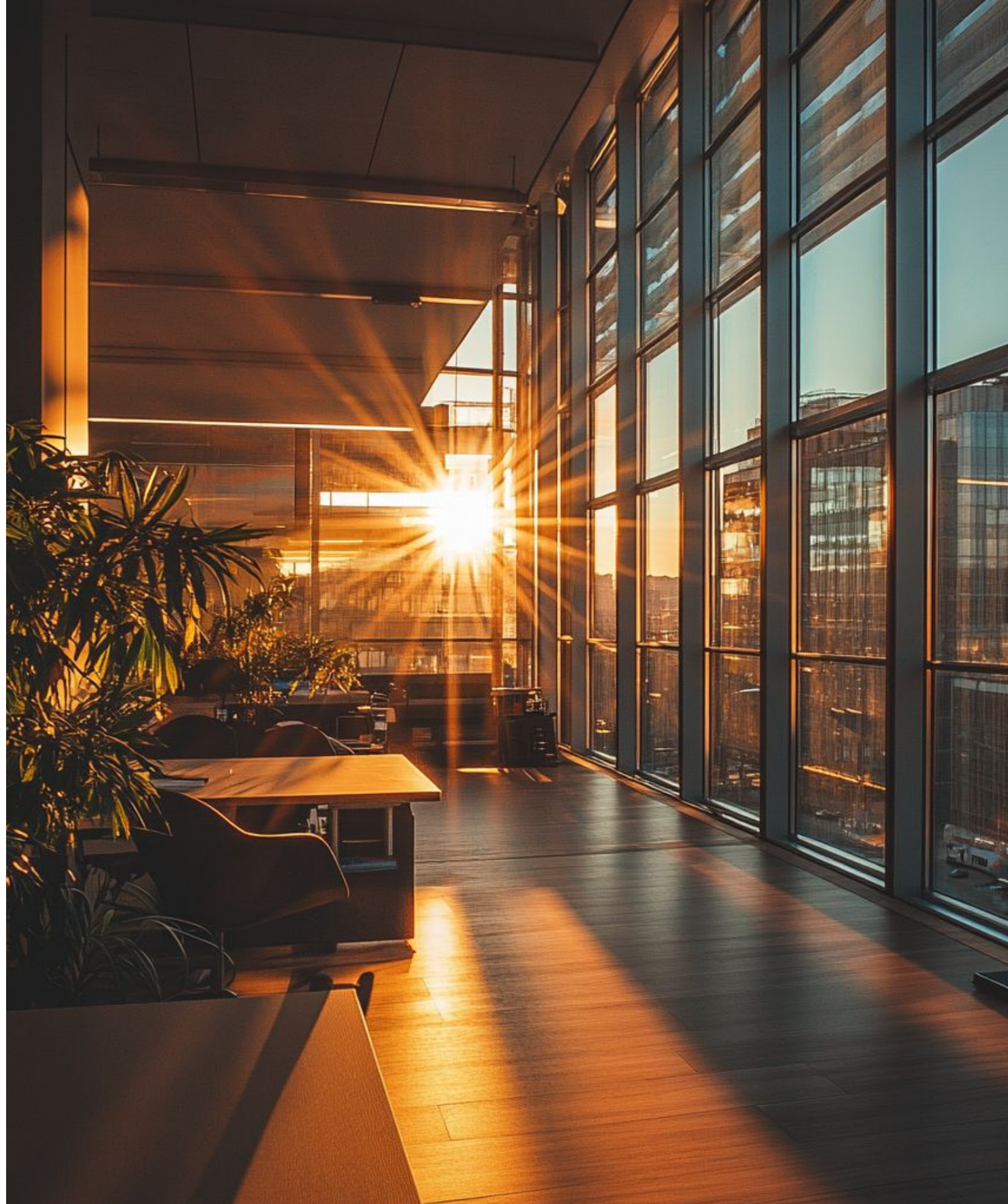


8. GOAL OVERVIEW

An overview of the 6 goals in the PCI DSS, and the associated requirements.



FUNDAMENTALS

FUNDAMENTALS GOAL OVERVIEW

As of v4.0.0, the PCI DSS have six major goals:

1. Build and Maintain a Secure Network and Systems
2. Protect Cardholder Data
3. Maintain a Vulnerability Management Program
4. Implement Strong Access Control Measures
5. Regularly Monitor and Test Networks
6. Maintain an Information Security Policy

These cover the breadth and depth of security measures expected to protect card data.

- Each goal is mapped to one or more requirements;

FUNDAMENTALS

GOAL OVERVIEW

This mapping is:

1. Build and Maintain a Secure Network and Systems
 - R1 (Keep a Firewall), R2 (No Defaults);
2. Protect Cardholder Data
 - R3 (Protect Stored Data), R4 (Protect Transmitted Data);
3. Maintain a Vulnerability Management Program
 - R5 (No Malware), R6 (Develop Securely);
4. Implement Strong Access Control Measures
 - R7 (NtK Access), R8 (Identify Access), R9 (Restrict Access)
5. Regularly Monitor and Test Networks
 - R10 (Log Everything), R11 (Test Regularly)
6. Maintain an Information Security Policy
 - R12 (InfoSec Policy);





FUNDAMENTALS

FUNDAMENTALS GOAL OVERVIEW

Although we are by no means required to know the goals by heart, they are good to put the requirements in context:

- For example, imagine we're implementing compliance controls for Req. 9 ("Restrict Access")
 - If we view it as a checklist, we're just implementing controls. CCTV, locked rooms, visitor badges, etc;
 - If we view it in the context of its goal ("Goal 4: Implement Strong Access Control Measures"), we understand it's part of a bigger whole. It's about limiting access, by bad actors, to our card data, and it complements other measures such as limiting access to data for users, identifying user IDs, and others;

In short, the goals help give color to our compliance controls.

FUNDAMENTALS

GOAL OVERVIEW

EXAMPLES

/01 PREDICTING THE FUTURE

There's no problem in just fulfilling requirements like a checklist. But knowing goals helps us go beyond. For this goal, what future actions would make sense here?

/02 COMPLEMENTING REQs.

Usually, within a goal, the requirements complement themselves. E.g., Goal 5 on Monitoring + Testing Networks. One req. is about logging, the other testing.

/03 FUTURE REQUIREMENTS

Knowing the PCI DSS goals could also be interesting to predict future requirements. If a new version brings future requirements, it will be inserted in a given goal.

FUNDAMENTALS

GOAL OVERVIEW

KEY TAKEAWAYS

/01 SIX MAJOR GOALS

The PCI DSS have six major goals, which cover the main areas to expect in terms of protecting card data (network security, data security, access control, etc).

/03 KNOWING THE CONTEXT

Although it's not necessary to know the goals, when fulfilling each requirement, we should be aware of its goal. This helps us put the security controls in context.

/02 MAPPED TO REQUIREMENTS

Each goal has one or more requirements that help fulfill it. For example, Protecting Cardholder Data includes protecting it when stored and transmitted.